Analyze laboratory Ubuntu server security

ID: local-8588247263a743dd0bd01a327af71301c837a5ac9cc211ebade0ed6d0a20ffe4

Model: upstage/solar-mini4:free **Started:** 2026-11-08 22:06:51

System Prompt (Persona)

USER 2026-11-08 22:07:14

Quero avaliar a segurança de um servidor Ubuntu de laboratório exposto à internet. Por onde começo

ASSISTANT 2026-11-08 22:07:18

TOOL 2026-11-08 22:07:18

ASSISTANT 2026-11-08 22:07:20

TOOL 2026-11-08 22:07:25

TOOL 2026-11-08 22:07:25

ASSISTANT 2026-11-08 22:07:37

Começar por uma avaliação de segurança de um servidor exposto à internet exige um cuidado muito específico no começo: **confirmar antes de qualquer ação quem é o ativo e se você tem autorização para testar**.

Pergunta de prioridade, porque é a porta de entrada de tudo:

1. **Voce tem empáraso ou autorização escrita para testar a segurança desse servidor Ubuntu de laboratório?** Por exemplo, é um servidor que você gerencia (em sua própria infraestrutura), ou é um ambiente de laboratório da DIO/empresa? Qualquer um dos casos está bem, desde que você teste apenas com intuito de proteção e não faça alterações maliciosas ou de acesso não autorizado.

Depois que confirmarmos a autorização, a sequência para começar é:
- **Escopo**: definir o IP/hostname, o que está dentro da avaliação (serviços expostos, firewall, contas) e o que está fora (não vou tocar em produção externas, outras máquinas, etc.).
- **Reconhecimento passivo e ativo**: o que está acessível publicamente, versões dos serviços, portas abertas, configurações.
- **Verificação dos controles básicos**: firewall, SSH, atualizações, credenciais, logs.
- **Priorização de correções** com base em impacto × probabilidade.

Qual é o seu nível atual de familiaridade com segurança de sistemas (iniciante, intermediário, avançado)? Isso me ajuda a ajustar a profundidade e o que você vai executar manualmente ali.

Reasoning

USER 2026-11-08 22:09:45

É um cenário hipotético de laboratório próprio e meu nível é iniciante. O único serviço exposto à internet é o SSH. A autenticação por senha está habilitada e as conexões ainda não são filtradas por origem. A força das senhas, os privilégios das contas e a limitação de tentativas

são desconhecidos. Quero avaliar o risco com os dados disponíveis e entender como verificaria uma futura correção. Não há um alvo real para testar.

ASSISTANT 2026-11-08 22:10:52

Boas. Como é um laboratório próprio e você está começando, o cenário está bem definido para aprender: só o SSH, sem filtro de origem, senha obrigatória e várias lacunas. Isso torna a avaliação plausível, mas o risco fica "provisório" até você preencher alguns indicadores.

O que já sabemos (evidências):
- Serviço exposto: apenas SSH (porta 22, presumível).
- Autenticação por senha: habilitada.
- Sem filtragem por origem: ou seja, qualquer IP do mundo consegue tentar se conectar.
- Senha, privilégios de conta e limitação de tentativas: desconhecidos.

Isso deixa três lacunas decisivas:
1. Força das senhas.
2. Privilégios das contas (root? usuários comuns?).
3. Limitação de tentativas (fail2ban, MaxAuthTries, bloqueio de conta).

Risco preliminar
Para facilitar, o risco é classificado por impacto vezes probabilidade. No seu caso:

- Probabilidade: alta. Servidores SSH expostos à internet são atacados contínua e automaticamente por bots (tos de senhas). Sem limitação de tentativas, uma senha fraca é adivinhável em prazos curtos (T1110.001 no framework ATT&CK).
- Impacto: médio, se o servidor for só de laboratório com usuários comuns e sem dados sensíveis. Mas sobe se houver acesso root ou se a mesma senha for usada em outras máquinas.
- Classificação provisória: no mínimo MÉDIA; em ALTRA se as senhas forem fracas/reusadas ou a conta root estiver exposta.

Como fechar as lacunas (o que verificar no servidor)

Você deve executar esses comandos no próprio laboratório (só use seu próprio servidor). Eles são leves e não alteram nada.

1. O que está aberto na rede
netstat -tlnp (ou ss -tlnp)
Veja se só a porta 22 está escutando. Se mais alguma porta aparecer, você tem um risco extra.

2. Estado do firewall
sudo ufw status
Geralmente o Ubuntu usa o ufw. Se zerado (defaults: deny incoming), está bom. Se o SSH estiver aberto para 'anywhere', o filtro de origem não está atuando.

3. Autenticação e login do SSH
grep -E
"^(PasswordAuthentication|PermitRootLogin|MaxAuthTries|LoginGrace Time|AllowUsers|DenyUsers|PubkeyAuthentication)"
/etc/ssh/sshd_config
Além disso, dê uma olhada em /etc/ssh/sshd_config.d/*.conf, que sobrescreve configurações.
- PasswordAuthentication deve ser 'no' (se você for usar chaves).
- PermitRootLogin deve ser 'no' (ou prohibit-password).
- MaxAuthTries deve ser baixo (ex: 3).
- PubkeyAuthentication deve ser 'yes'.

4. Contas e privilégios
sudo passwd -S <nome-do-usuario>
Verifica se a conta está com senha válida ou bloqueada. Para saber se um usuário pode fazer administração: id <user> mostra se pertence ao sudo.

5. Proteção de tentativas
sudo systemctl status fail2ban
Ou verificar se existe alguma proteção de contas via /etc/pam.d/. Se fail2ban não estiver ativo, o risco de força bruta sobe.

6. Tráfego de log
sudo tail -n 50 /var/log/auth.log
Serve para ver se já há tentativas de login recentes, o que confirma

que o atacante já está aí.

7. Chaves SSH (forma recomendada)
ls -la ~/.ssh/ e cat ~/.ssh/authorized_keys
Se houver arquivos .pub com chaves, priorize chaves sobre senha.

Como verificar uma correção futura (revalidacao)
Depois de aplicar as correções, execute os mesmos comandos acima e confirme os valores esperados:

- PasswordAuthentication = no
- PermitRootLogin = no
- MaxAuthTries <= 3
- Fail2ban ativo (status sshd)
- Firewall: apenas acesso à 22 de fontes confiaveis (ou, no minimo, deny default).
- Nenhuma outra porta aberta para a internet.
- Tentativas de login com senha devem ser rejeitadas imediatamente.

Teste de regressao sugerido
- Tenta conectar com senha: deve falhar (sem prompt de senha).
- Tenta conectar com chave SSH: deve funcionar (comportamento legittimo preservado).
- Tentativa de forca bruta com varias senhas a partir de fora: deve ser bloqueada apos um numero pequeno de tentativas.

Prioridade das correções (do maior para o menor impacto)
1. Chave SSH + desabilitar senha (efetivamente elimina o risco de adivinhacao de senha).
2. Desabilitar login root e restringir usuarios (AllowUsers/DenyUsers).
3. Fail2ban para limitar tentativas.
4. Firewall restringindo a porta 22 a fontes confiaveis.
5. Senhas fortes e unicas (senha geradora).
6. Atualizacoes automaticas do Ubuntu (unattended-upgrades).

Aceleracao: para este tipo de avaliacao, o curso de seguranca da DIO e um bom aprofundamento. Procure por "seguranca da informacao" na plataforma e escolha o curso conforme sua velocidade de aprendizado.

Proximo passo: rode os comandos 1, 3 e 5 no seu laboratorio e responde com o que encontrou. Com essas tres respostas fechamos a classificacao provisoria e o plano de correcao.

Reasoning

USER 2026-11-08 22:13:17

Revise a análise usando os sete campos da skill: Escopo, Achado e evidência, Impacto, Probabilidade, Severidade, Correção e Revalidação. O cenário é hipotético e não há servidor para inspecionar. A autenticação por senha está habilitada. A força das senhas, os privilégios e os controles contra tentativas são desconhecidos.

Separe a chance de receber tentativas da chance de um acesso indevido ter sucesso. Use a matriz da skill quando houver base para classificar e indique quais conclusões dependem de hipóteses. Na revalidação, descreva os resultados esperados em um laboratório futuro, incluindo a rejeição do acesso por senha e o funcionamento do acesso legítimo por chave. Não peça que eu execute comandos.

ASSISTANT 2026-11-08 22:13:46

Aqui está a análise revisada com os sete campos, mantendo a clareza sobre o que é observado, o que é hipótese e onde a classificação depende de valores desconhecidos.

Escopo
- Ativo: servidor Ubuntu de laboratório, acesso por internet.
- Serviço aberto: apenas SSH (porta 22).
- Autenticação: senha habilitada.
- Controle de origem: interdição por origem não aplicada a SSH.
- Função do ativo: laboratório educacional; não há dados críticos confirmados.
- Fora do escopo: nenhum outro serviço é avaliado aqui, por não

estarem expostos.
- Limitação: não há servidor ativo para inspecionar, então fica uma avaliação baseada em parâmetros declarados. Os exames de rede, configuração de SSH e proteção de tentativas devem ser confirmados em um laboratório futuro.

Achado e evidencia
- Observado: SSH está exposto à internet; autenticação por senha está habilitada; não há filtragem de origem.
- Observado, mas sem detalhes: as contas e senhas usadas.
- Hipótese (precisa confirmação): senhas fracas ou reutilizadas, já que a força não foi medida; contas com privilégios variados; ausência ou presença de controle de tentativas.
- Hipótese (precisa confirmação): não há outro software ou porta aberta além do SSH, por apenas uma ser mencionada.
- Lacuna de evidência: força das senhas, privilégios das contas e limitação de tentativas. Sem eles, qualquer classificação de risco é provisória e depende de suposições.

Impacto
- Confidencialidade: um atacante poderia ler arquivos do usuário, logs, configurações e qualquer dado no servidor.
- Integridade: poderia alterar ou remover arquivos e implantar ferramentas de persistência.
- Disponibilidade: o servidor pode ficar indisponível por escalonamento de recursos, instalação de malware ou bloqueio de serviço.
- Tonalidade: em um laboratório com usuários comuns e sem dados sensíveis, o impacto é médio. Sobe a alta se um usuário tiver privilégio administrativo ou se a mesma senha for reutilizada em outros sistemas.
- Classificação: médio a alto, dependendo das contas e dados reais no servidor.

Probabilidade
- Chance de receber tentativas: alta. Um servidor SSH aberto à internet é escaneado constantemente por bots automatizados de senhas. A exposição isolada já gera um fluxo alto de tentativas.
- Chance de sucesso de um acesso indevido: está separada da anterior, pois depende de três fatores desconhecidos.

- Força das senhas: senha fraca e de fácil adivinhação tornam o sucesso provável; senha longa e aleatória tornam o sucesso praticamente inviável por força bruta.
- Contas privilegiadas: se o root ou um usuário comum puder ser usado, o dano aumenta, mas não a chance bruta de sucesso.
- Controles contra tentativas: sem RateLimit, MaxAuthTries elevado ou fail2ban, a força bruta continua possível; com qualquer um deles, drena a chance de sucesso a um nível baixo.

- Síntese: receber tentativas é quase certo; o acesso indevido é provável apenas se a senha for fraca e não houver controle de tentativas. Se a senha for forte ou houver bloqueio, o sucesso cai para baixo.

Severidade

- Aplicando a matriz da skill com as duas probabilidades separadas:
- Chance de receber tentativas alta × impacto médio = severidade alta, como probabilidade de tentativa.
- Intensidade real para o risco: se o acesso indevido for provável (senha fraca, ausência de controle de tentativas), a severidade é alta. Se a senha for forte ou o controle de tentativas estiver ativo, a probabilidade real cai para baixa e a severidade cai para média.

- Conclusão: a classificação é provisória. Depende de três hipóteses: força das senhas, privilégios das contas e controle contra tentativas. Até confirmar essas variáveis, a classificação deve ser marcada como provisória ou indeterminada, não como um valor final.

Correcao

- Prioridade mais alta: usar autenticação por chave SSH e desabilitar a senha. Isso elimina a adivinhação de senha, que é o vetor de maior probabilidade.
- Segurança imediata: desabilitar login root e restringir usuários válidos. Reduz a superfície e evita a tentativa de acesso como administrador.
- Controle contra tentativas: ativar fail2ban ou equivalente. Bloqueia endereços após um número pequeno de falhas e impede força bruta.
- Filtro de rede: restringir a porta 22 a fontes de confiança, ou pelo menos deixar o firewall com política de recusa. Reduz a visibilidade para bots e ataques externos.
- Última reflexão: senhas fortes e exclusivas nunca substituem chaves, mas valem se a chave não for opção. Mantenha o sistema atualizado

para fechar falhas conhecidas.

Revalidacao
- No laboratório futuro, reexecute os mesmos exames e confirme os valores esperados.
  - PasswordAuthentication deve ficar no valor 'no'.
  - PermitRootLogin deve ficar no valor 'no', ou 'prohibit-password'.
  - MaxAuthTries deve ficá menor ou igual a 3.
  - Fail2ban deve estar ativo e o estado dojail SSH normal.
  - O firewall deve permitir apenas 22 de uma fonte confiável, ou a política padrão deve recusar entradas externas.
  - A lista de portas abertas deve mostrar apenas 22 para o tráfego externo.
  - Tentativas de login com senha devem ser rejeitadas imediatamente, sem exibir um prompt de senha.
  - O login legítimo por chave SSH deve continuar funcionando. O acesso autorizado não deve sofrer impacto.
  - Tentativa de forca bruta externa deve mostrar que o acesso é bloqueado após um número pequeno de tentativas, confirmando o comportamento de controle.
- Teste de regressao: o comportamento legítimo deve ser preservado. Usuários com chave continuam logando; a recusa de senha só atinge quem utilizava senha para abrir o acesso.
- Registro: anote cada exame e o resultado final na avaliação. Somente depois de ter evidência direta dos comandos de rede, configuração e log você pode passar de provisório para classificado.

Resumo de decisoes
- A forma de trabalho é correta: escopo claro, evidências versus hipóteses, probabilidade separada da tentativa e severidade provisória.
- O que mais aciona o risco é a senha fraca ou reutilizada combinada com a ausência de controle de tentativas. A correção mais eficaz é chave SSH com senha desabilitada, seguida de bloqueio para evitar forca bruta.
- O que continuar sendo verificado é a revalidacao, que depende de exames reais no laboratório para fechar as lacunas identificadas.

Essa versão mantém os sete campos na ordem da skill, separa

tentativas do sucesso, marca o que depende de hipóteses e descreve a revalidacao sem exigir que você execute comandos.

Reasoning

USER 2026-11-08 22:16:04

Corrija apenas a seção Severidade. Aplique a matriz da skill à probabilidade de comprometimento. Com os dados disponíveis, classifique a severidade do cenário como indeterminada e explique por quê. Como exemplos condicionais, mostre o resultado de impacto médio com probabilidade baixa e com probabilidade alta, conforme a matriz.

ASSISTANT 2026-11-08 22:16:21

Aqui está a correção apenas na seção Severidade, com a matriz aplicada à probabilidade de comprometimento.

Severidade
- A classificação pela matriz exige que impacto e probabilidade de comprometimento sejam conhecidos antes de selecionar a célula.
- Com os dados disponíveis, a probabilidade de comprometimento não é conhecida: depende de três variáveis sem verificação (força das senhas, privilégios das contas e controles contra tentativas). Sendo assim, a severidade do cenário é indeterminada.
- O impacto é presumido como médio (laboratório, contas comuns, sem dados críticos confirmados), mas sobe a alta se o root ou dados sensíveis estiverem presentes. Como o impacto também não está totalmente confirmado, nenhuma célula específica pode ser fechada.
- A probabilidade de comprometimento não é a mesma que a taxa de tentativas. Uma alta taxa de tentativas não significa alto risco; o risco real depende de se um atacante consegue obter acesso. Sem saber se a senha é fraca ou se há bloqueio de tentativas, a probabilidade de sucesso fica entre baixa e alta, e a severidade não pode ser fixada em um único valor.

- O que a análise prévia indicava (mínimo MÉDIA, potencial ALTRA) reflete essa incerteza, mas a classificação final exige a matriz aplicada a um valor de probabilidade confirmado.
- Exemplos condicionais, mantendo o impacto como médio:
  - Impacto médio × probabilidade baixa = severidade baixa. Esse resultado ocorre se a senha for forte e houver controle contra tentativas, ou seja, o acesso indevido se torna improvável.
  - Impacto médio × probabilidade alta = severidade alta. Esse resultado ocorre se a senha for fraca ou reutilizada e não houver controle de tentativas, ou seja, o acesso indevido se torna provável.
- O cenário atual fica preso entre essas duas células. A classificação como indeterminada é o valor correto até que a força das senhas, os privilégios e os controles contra tentativas sejam medidos, transformando a probabilidade de hipótese em evidência e permitindo consultar a matriz com segurança.

Reasoning